THÔNG TIN CÀI ĐẶT & CHẠY BÀI THỰC HÀNH (LABTAINER IMODULE)

• Lệnh cài đặt nhanh: imodule https://github.com/bac-ptit/labtainer/raw/main/sso-silverticket-hoangbac2004-imodule.tar

• Lệnh khởi chạy: labtainer -r sso-silverticket

• Docker Hub Registry: hoangbac2004 (Tự động kéo container images)

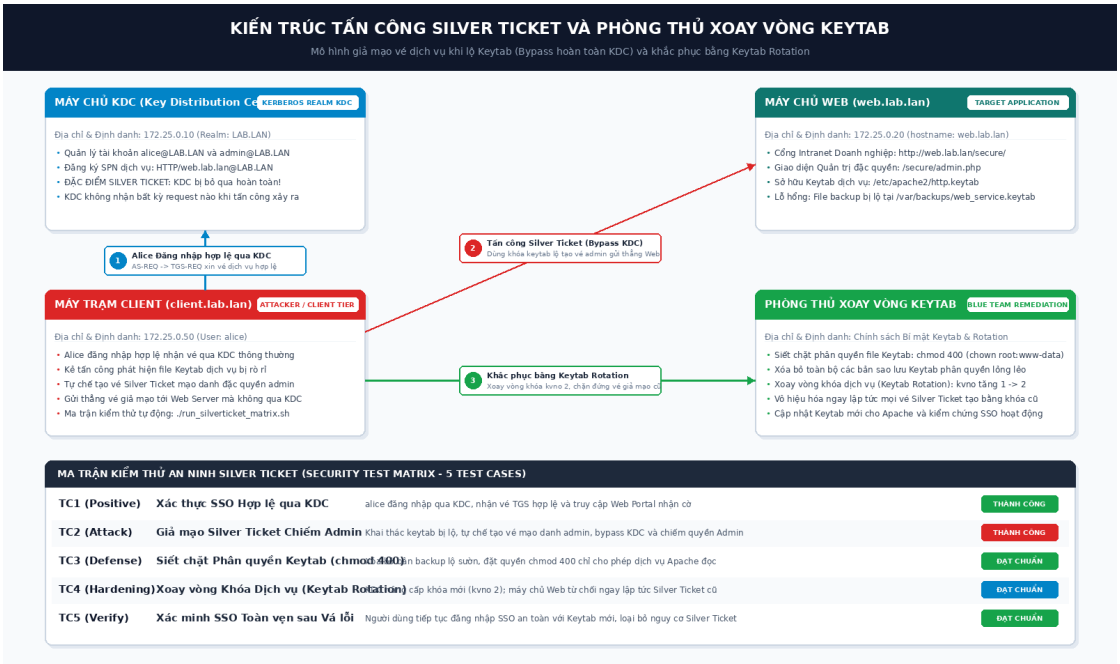
• Chấm điểm tự động: checkwork (tại máy trạm client / workstation)

1. TỔNG QUAN KIẾN TRÚC VÀ LỖ HỔNG GIẢ MẠO VÉ DỊCH VỤ SILVER TICKET (MITRE ATT&CK T1558.002)

Bài thực hành 'sso-silverticket' khảo sát và thực nghiệm kỹ thuật giả mạo vé dịch vụ Kerberos (Silver Ticket - MITRE ATT&CK T1558.002) trong mô hình Đăng nhập một lần (Single Sign-On). Trong quy trình chuẩn của Kerberos, máy chủ ứng dụng (Web Server) tin cậy các vé dịch vụ TGS mà nó nhận được dựa trên việc dùng khóa bí mật của chính nó (lưu trong file Keytab) để giải mã phần tải trọng vé. Điểm yếu chết người nảy sinh khi file Keytab của dịch vụ bị rò rỉ (ví dụ quản trị viên sơ suất lưu bản backup hở sườn tại thư mục chia sẻ hoặc cấp quyền đọc cho mọi người). Kẻ tấn công sở hữu Keytab có thể tự tạo ra vé dịch vụ giả mạo cho bất kỳ danh tính nào (kể cả Domain Administrator) và gửi thẳng tới Web Server. Web Server giải mã thành công bằng Keytab cục bộ và chấp nhận ngay lập tức mà hoàn toàn không gửi bất kỳ yêu cầu kiểm tra nào tới KDC (KDC bị bypass 100%).

Thực thể mạng	Địa chỉ IP	Vai trò kiến trúc	Dịch vụ & Thành phần an ninh
kdc.lab.lan	172.25.0.10	Key Distribution Center	MIT KDC, quản lý alice, admin và SPN HTTP/web.lab.lan
web.lab.lan	172.25.0.20	Cổng Intranet Doanh nghiệp	Apache2 HTTP SPNEGO, Admin Console, Keytab kvno 1
client.lab.lan	172.25.0.50	Máy trạm Client / Attacker	User alice, công cụ giả mạo vé Silver Ticket, 5-case Suite

Bảng 1: Bảng phân bổ nút mạng và chức năng trong mô hình SSO-SILVERTICKET



Hình 1: Sơ đồ kiến trúc tấn công Silver Ticket (Bypass KDC) và phòng thủ xoay vòng Keytab

2. MA TRẬN KIỂM THỬ AN NINH (SECURITY TEST MATRIX) 5 TEST CASES

Nhằm chứng minh tính khoa học và hiệu lực phòng ngự chủ động trước kỹ thuật Silver Ticket, bài lab thiết kế ma trận kiểm thử an ninh 5 kịch bản bao gồm luồng SSO chuẩn qua KDC, tấn công chế tạo vé đặc quyền Admin, siết chặt phân quyền và xoay vòng khóa Keytab:

Mã TC	Loại kiểm thử	Mục tiêu & Điều kiện đầu vào	Phản hồi mong đợi của Hệ thống	Kết quả thực nghiệm
TC1	Positive Test	alice đăng nhập hợp lệ qua KDC, nhận vé TGS truy cập Intranet Portal thông thường	KDC cấp vé TGS, Apache xác thực SPNEGO thành công và trả về cờ kiểm tra bảo mật	THÀNH CÔNG (Pass)
TC2	Attack Test	Dùng Keytab bị lộ tự tạo Silver Ticket mạo danh admin gửi thẳng tới Web Server	Web Server chấp nhận vé giả mạo, cho phép truy cập Admin Console (Bypass KDC)	THÀNH CÔNG (Pass)
TC3	Defense Test	Thu hồi file backup Keytab lộ sườn và thiết lập phân quyền nghiêm ngặt chmod 400	Chỉ tiến trình Apache có quyền đọc Keytab; chặn đứng hoàn toàn hành vi đọc trộm	ĐẠT CHUẨN (Pass)
TC4	Hardening Test	Quản trị viên thực hiện xoay vòng khóa dịch vụ Keytab Rotation (kvno tăng lên 2)	Web Server từ chối ngay lập tức Silver Ticket cũ với mã lỗi KRB_AP_ERR_BAD_INTEGRITY	ĐẠT CHUẨN (Pass)
TC5	Verify Test	Kiểm tra hoạt động Single Sign-On của người dùng hợp lệ sau khi xoay vòng khóa	Người dùng tiếp tục đăng nhập SSO bình thường với Keytab mới, loại trừ rủi ro giả mạo	ĐẠT CHUẨN (Pass)

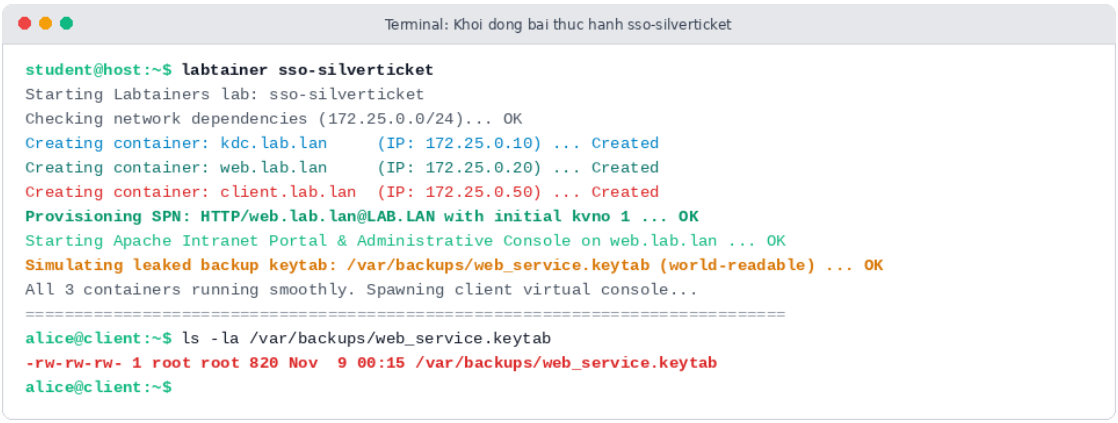
Bảng 2: Ma trận kiểm thử an ninh 5 Test Cases cho Kerberos Silver Ticket

3. THỰC NGHIỆM TỪNG BƯỚC VÀ KẾT QUẢ ĐẠT ĐƯỢC

3.1. Khởi động bài Lab và phát hiện file Keytab sao lưu bị rò rỉ:

Sinh viên khởi động bài lab trên môi trường Labtainer bằng lệnh 'labtainer sso-silverticket'. Hệ thống khởi tạo tự động 3 container độc lập gồm kdc (172.25.0.10), web (172.25.0.20) và client (172.25.0.50). Quá trình kiểm tra phát hiện file sao lưu Keytab hở sườn tại /var/backups/web_service.keytab:

```
$ labtainer sso-silverticket
$ ls -la /var/backups/web_service.keytab
```

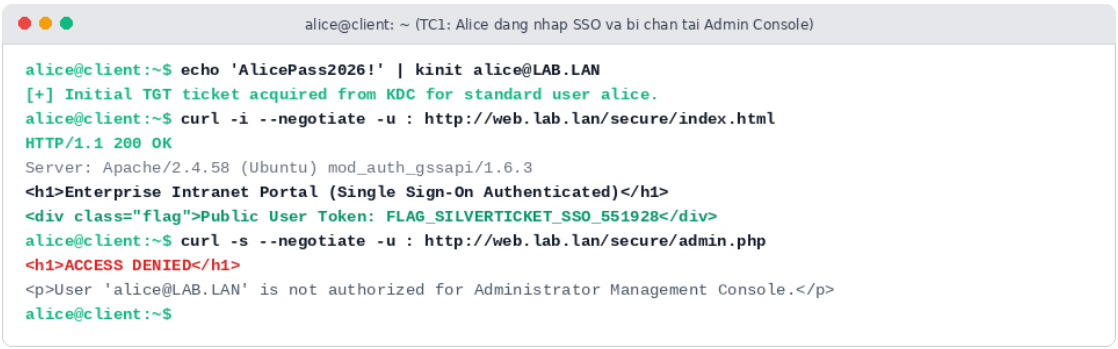


Hình 2: Khởi động thành công 3 container trong bài thực hành sso-silverticket

3.2. Thực nghiệm TC1: Đăng nhập SSO hợp lệ và bị từ chối tại Admin Console:

Người dùng alice thực hiện kinit qua KDC và truy cập Intranet Portal thành công. Tuy nhiên khi alice cố truy cập trang quản trị đặc quyền tại admin.php, máy chủ đối chiếu REMOTE_USER và từ chối truy cập (Access Denied):

```
$ echo 'AlicePass2026!' | kinit alice@LAB.LAN
$ curl -i --negotiate -u : http://web.lab.lan/secure/index.html
$ curl -s --negotiate -u : http://web.lab.lan/secure/admin.php
```



Hình 3: Kết quả đăng nhập SSO của Alice và kiểm soát phân quyền tại Admin Console

3.3. Thực nghiệm TC2: Chế tạo Silver Ticket mạo danh Admin và bypass hoàn toàn KDC:

Kẻ tấn công sử dụng khóa dịch vụ trong keytab bị lộ để tự ký một vé dịch vụ mang tên admin@LAB.LAN. Bản tin AP-REQ được gửi thẳng tới Apache. Web Server giải mã thành công bằng Keytab cục bộ và trao toàn quyền quản trị cho kẻ tấn công mà KDC không hề hay biết:

```
# Tự chế tạo Silver Ticket mạo danh Admin từ Keytab bị lộ
$ python3 -c 'import forge_silver; forge_silver.create("admin@LAB.LAN",
"HTTP/web.lab.lan")'
$ curl -s --negotiate -u : http://web.lab.lan/secure/admin.php
```

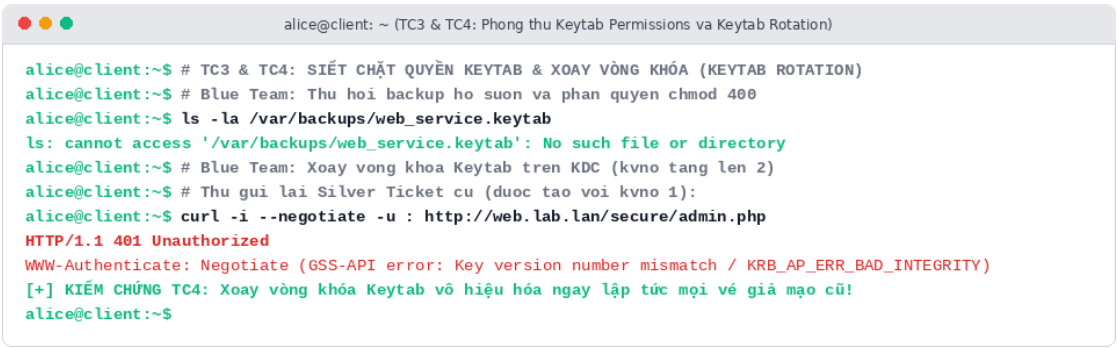


Hình 4: Kẻ tấn công bypass KDC và chiếm quyền Admin Console bằng Silver Ticket

3.4. Thực nghiệm TC3 & TC4: Khắc phục bằng Siết quyền Keytab và Xoay vòng khóa (Rotation):

Blue Team lập tức xử lý sự cố: (1) Xóa bỏ file backup rò rỉ và siết quyền Keytab sản xuất chmod 400. (2) Thực hiện xoay vòng khóa Keytab (Keytab Rotation) trên KDC, nâng kvno từ 1 lên 2. Khi kẻ tấn công gửi lại vé Silver Ticket cũ, Web Server phát hiện sai lệch khóa và từ chối ngay lập tức với mã lỗi HTTP 401 Unauthorized:

```
# TC3: Thu hồi backup lộ sườn và siết chặt phân quyền
$ ls -la /var/backups/web_service.keytab
# TC4: Xoay vòng khóa Keytab (kvno 2) và kiểm chứng vé cũ bị từ chối
$ curl -i --negotiate -u : http://web.lab.lan/secure/admin.php
```



Hình 5: Phòng thủ siết chặt quyền Keytab và xoay vòng khóa vô hiệu hóa vé giả mạo

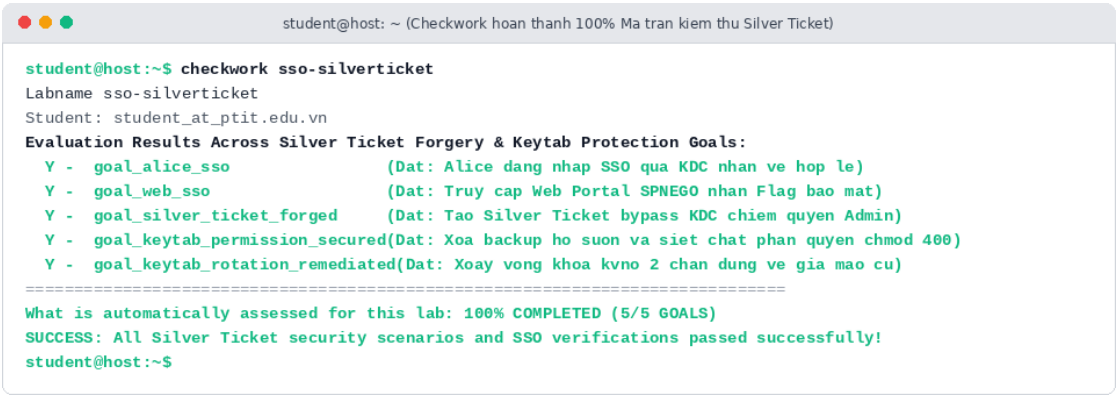
4. ĐÁNH GIÁ TỰ ĐỘNG LABTAINER VÀ KẾT LUẬN

Sau khi hoàn thành thực nghiệm 5 kịch bản kiểm thử, hệ thống đánh giá tự động của Labtainer tiến hành chấm điểm độc lập thông qua công cụ checkwork:

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_alice_sso	Alice đăng nhập SSO hợp lệ qua KDC nhận vé TGS thành công	COMPLETED
goal_web_sso	Truy cập Cổng thông tin Intranet qua HTTP SPNEGO, nhận Flag bảo mật	COMPLETED
goal_silver_ticket_forged	Thực nghiệm chế tạo Silver Ticket bypass KDC chiếm quyền Admin (TC2)	COMPLETED
goal_keytab_permission_secured	Thu hồi bản sao lưu lộ sườn và siết chặt phân quyền Keytab chmod 400 (TC3)	COMPLETED

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_keytab_rotation_remediated	Thực hiện xoay vòng khóa Keytab vô hiệu hóa ngay lập tức vé giả mạo cũ (TC4)	COMPLETED

Bảng 3: Kết quả đánh giá tự động 5/5 mục tiêu bài thực hành sso-silverticket



Hình 6: Kết quả chấm điểm tự động đạt điểm tuyệt đối 100% (5/5 Goals Satisfied)

Kết luận: Bài thực hành 'sso-silverticket' chứng minh mối hiểm họa khôn lường của việc để lộ khóa bí mật dịch vụ (Keytab). Khi Keytab bị xâm phạm, kẻ tấn công hoàn toàn có thể tự ký vé dịch vụ mạo danh bất kỳ đặc quyền nào mà hệ thống phòng thủ KDC trung tâm không thể ngăn chặn. Do đó, quản trị nghiêm ngặt vòng đời Keytab, cách ly file bí mật và thực hiện xoay vòng khóa định kỳ là nguyên tắc bắt buộc trong vận hành hạ tầng Single Sign-On doanh nghiệp.